Incident Report: Lumma Stealer C2 Activity Analysis

Malware-Traffic-Analysis.net Exercise – 2026-01-31 "Lumma in the Room-ah"

Analyst:Denise Sophy

Date of Analysis:March 18, 2026

Exercise Source:malware-traffic-analysis.net

Objective:Blind reconstruction of infected host profile and C2 communication from raw PCAP using only the provided alert intelligence.

INTRODUCTION

This report documents the step-by-step analysis of a packet capture (PCAP) containing Lumma Stealer (LummaC2) victim fingerprinting and exfiltration activity.

The exercise provided:

- An Emerging Threats (ET) signature alert: "ET MALWARE Lumma Stealer Victim Fingerprinting Activity"

- Trigger details: outbound traffic from an internal host to external IP **153.92.1.49** over TCP port 80

- Environment context: LAN range 10.1.21.0/24, domain win11office.com, DC at 10.1.21.2 (WIN-LU4L24X3UB7)

Goal: Identify the infected host, extract artifacts (IP, MAC, hostname, user account, full name), confirm the C2 domain and behavior — all without walkthroughs, external answers, or prior knowledge of the PCAP contents.

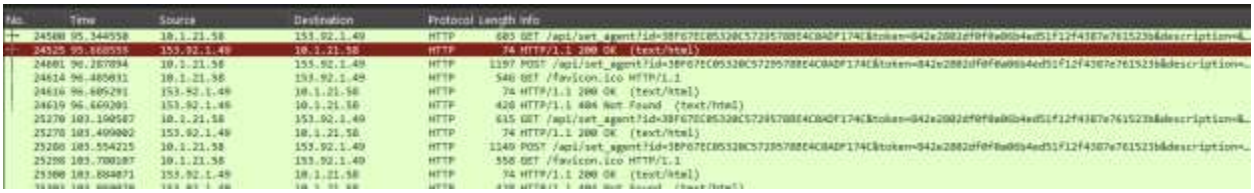
Analysis performed using Wireshark with strict IOC-led filtering and multi-protocol correlation.

Step-by-Step Findings

Step 1 – Alert IOC Filtering & Victim IP Identification

Applied initial display filter: `ip.addr == 153.92.1.49 && http`

Immediately isolated persistent outbound HTTP/80 traffic from a single internal host.



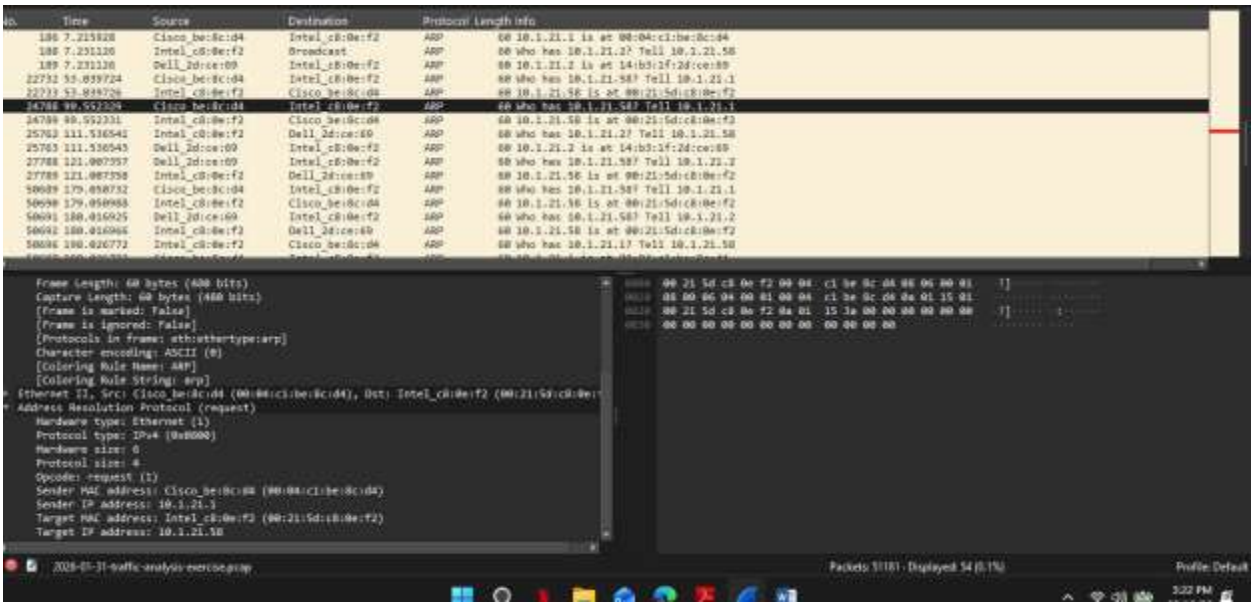
No.	Time	Source	Destination	Protocol	Length	Info
24500	95.344558	10.1.21.58	153.92.1.49	HTTP	685	GET /api/set_agent?id=3BF67EC85320C57295708E4C8ADF174C&token=842a2882df0f0a00b4ed51f12f4387e761523b&description=&…
24525	95.660555	153.92.1.49	10.1.21.58	HTTP	74	HTTP/1.1 200 OK (text/html)
24601	96.287094	10.1.21.58	153.92.1.49	HTTP	1197	POST /api/set_agent?id=3BF67EC85320C57295708E4C8ADF174C&token=842a2882df0f0a00b4ed51f12f4387e761523b&description=…
24614	96.485831	10.1.21.58	153.92.1.49	HTTP	548	GET /favicon.ico HTTP/1.1
24616	96.605291	153.92.1.49	10.1.21.58	HTTP	74	HTTP/1.1 200 OK (text/html)
24619	96.669201	153.92.1.49	10.1.21.58	HTTP	420	HTTP/1.1 404 Not Found (text/html)
25270	103.190587	10.1.21.58	153.92.1.49	HTTP	615	GET /api/set_agent?id=3BF67EC85320C57295708E4C8ADF174C&token=842a2882df0f0a00b4ed51f12f4387e761523b&description=&…
25278	103.409002	153.92.1.49	10.1.21.58	HTTP	74	HTTP/1.1 200 OK (text/html)
25280	103.554215	10.1.21.58	153.92.1.49	HTTP	1149	POST /api/set_agent?id=3BF67EC85320C57295708E4C8ADF174C&token=842a2882df0f0a00b4ed51f12f4387e761523b&description=…
25298	103.700187	10.1.21.58	153.92.1.49	HTTP	558	GET /favicon.ico HTTP/1.1
25300	103.884071	153.92.1.49	10.1.21.58	HTTP	74	HTTP/1.1 200 OK (text/html)

Finding:Infected client IP =10.1.21.58

Wireshark packet list showing filtered HTTP traffic to 153.92.1.49 with source 10.1.21.58 highlighted

Step 2 – MAC Address Extraction
ARP filter `arp` returned no direct entries for 10.1.21.58 in the capture window.

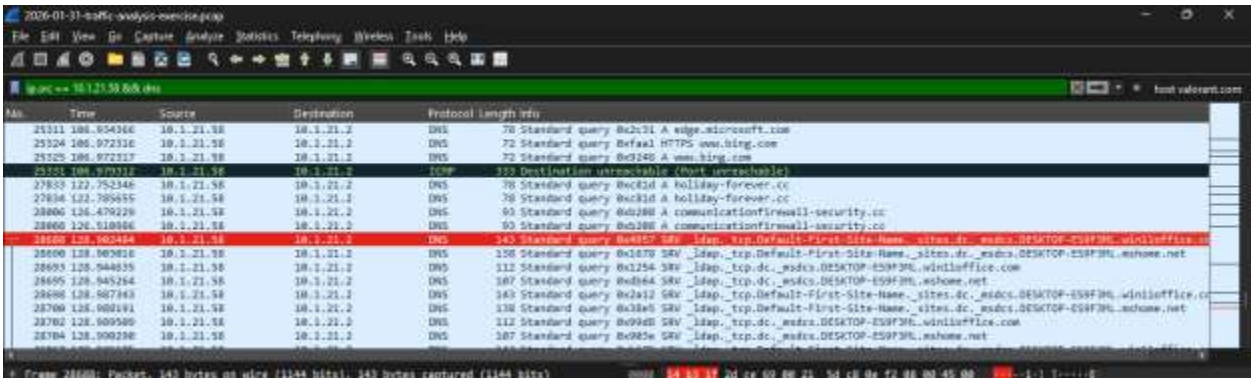
Switched to Ethernet II source MAC on outbound packets from 10.1.21.58.



Finding:MAC address =00:21:5d:c8:0e:f2

Step 3 – Hostname Discovery
Filter: `ip.src == 10.1.21.58 && dns`

→ No obvious A record for own name. Expanded to SRV records and observed repeated LDAP/Kerberos discovery queries.



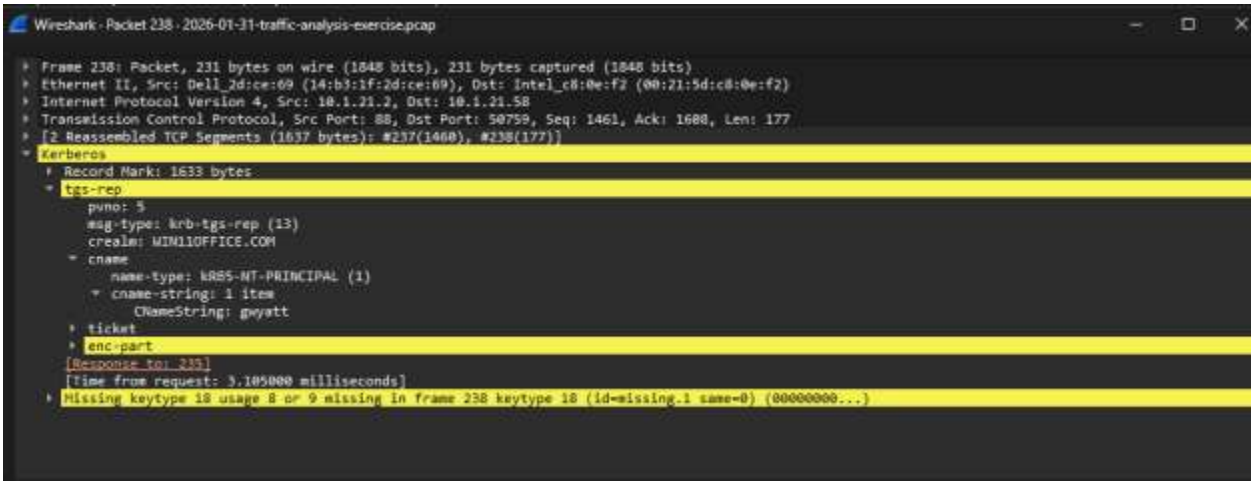
Finding: Hostname = DESKTOP-ES9F3ML

Step 4 – User Account Name Identification
Filter: `ip.src == 10.1.21.58 && kerberos`

Kerberos AS-REQ / TGS-REP packets revealed the client principal.

Finding: User account name = **gywyatt**

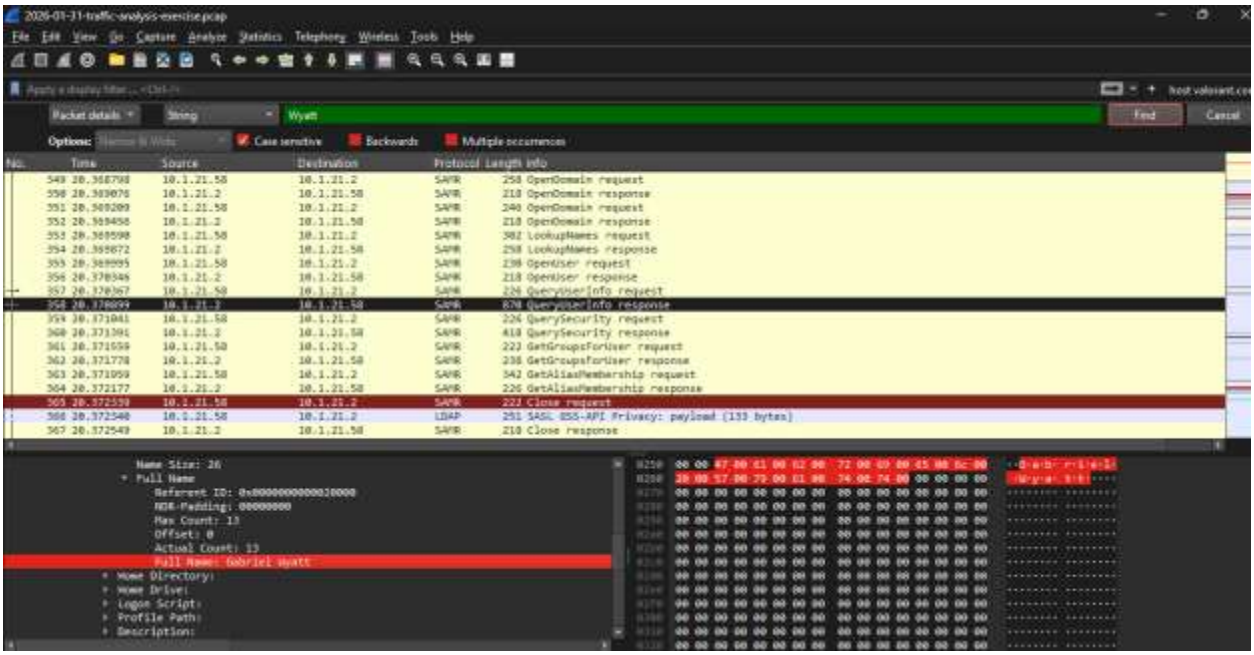
(From cname-string in TGS-REP: gwyatt@WIN11OFFICE.COM)



Step 5 – Full Name Extraction

String search for "Wyatt" across the PCAP → located SAMR (Security Account Manager Remote) traffic.

Kerberos.CNameString



Finding: Full name =Gabriel Wyatt

Step 6 – C2 Domain & Malicious Behavior Confirmation
Followed HTTP streams from 10.1.21.58 to 153.92.1.49.

Observed:

- GET /api/set_agent?... (fetches fingerprinting JavaScript)

- POST /api/set_agent?...&act=log (exfils 8023-byte URL-encoded JSON)

- JSON contents: system info, WebGL (AMD Radeon R9 200 Series), canvas fingerprint (base64 PNG), fonts list, screen resolution 1920×1080, hardwareConcurrency 12, etc.

Finding: C2 domain = **whitepepper.su**

Wireshark · Follow TCP Stream (tcp.stream eq 99) · 2026-01-31-traffic-analysis-exercise.pcap

```
GET /api/set_agent?id=3BF67EC05320C5729578BE4C0ADF174C&token=842e2802df0f0a06b4ed51f12f4387e761523b&description=&agent=Chro
me HTTP/1.1
Host: whitepepper.su
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed
-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9


HTTP/1.1 200 OK
Server: nginx/1.29.1
Date: Tue, 27 Jan 2026 23:05:39 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Content-Encoding: gzip
```

Behavior matches documented Lumma Stealer adaptive browser/system fingerprinting.

CONCLUSION & LESSONS LEARNED

This blind analysis successfully transformed a single external IOC into a complete victim profile (IP, MAC, hostname, user account, full name) and confirmed Lumma Stealer C2 behavior — all without external references or walkthroughs.

1. IOC-first filtering is non-negotiable

   Leading with the alert IP (153.92.1.49) reduced a ~21 MB PCAP to a handful of relevant flows within seconds.

2. Victim identification unlocks everything else

   Once the infected IP is known, MAC (Ethernet/ARP), hostname (DNS/SRV/NBNS), user (Kerberos), and profile data (SAMR/LDAP) cascade naturally.

3. Hostname often hides in SRV or NetBIOS registrations

   Standard A queries were clean; SRV records (_ldap...) revealed the workstation name.

4. Kerberos reveals the authenticating principal

   Machine accounts ($) appear first in SYSTEM-context malware; user principals appear in TGS-REP for session activity.

5. SAMR QueryUserInfo is gold for full name

   When Kerberos gives username, SAMR gives the human-readable full name (Gabriel Wyatt).

6. Stealer fingerprinting blends with legitimate traffic

   Large POST bodies, unusual endpoints (/api/set_agent), and adaptive data (canvas hash, WebGL renderer) are red flags once domain is known.

7. Persistence & iteration beat initial failure

   Early dead-ends (no ARP, no obvious DNS) were overcome by broadening filters, string searching usernames, and chaining protocols.

This exercise significantly improved my packet-level hunting, AD authentication dissection, and IOC-led incident reconstruction skills — core competencies for SOC analyst and DFIR roles.

Total time invested: ~3–4 focused hours across multiple sessions

Tools used: Wireshark only (display filters, stream following, string search)